

Software applications are evaluated using DAST. This testing simulates the actions of a malicious party trying to access an application remotely. Software applications are continuously scanned by DAST for security holes using market-leading vulnerability sources like the Open Web Application Security Project (OWASP Top 10), Common Weakness Enumeration (CWE) and SysAdmin, Audit, Network and Security (SANS). OWASP is a standard document for developers and web security; it includes injection (SQL injections, command injections, CRLF injections, and LDAP injections), broken authentication, sensitive data exposure, XML external entities, broken access control, security misconfiguration, cross-site scripting, insecure deserialization, using components with known vulnerabilities, and insufficient logging and monitoring.

The main difference between DAST and SAST (static application security testing) is how each approaches security testing. SAST scans the application code while it is at rest to look for defective code that provides a security danger, whereas DAST analyses the operational program without having access to its source code.

DAST is a type of closed-box testing that simulates the viewpoint of an external attacker. It is assumed that the tester is unaware of the inner workings of the program. It can find security flaws that manifest themselves only during software runtime.

Acunetix

One of the DAST tools is Acunetix. Although there are numerous tools available today, Acunetix offers a free trial as well as membership services for premium features like speed and accuracy. It is a superior tool that is quick and accurate, and it also has a user-friendly interface that makes it simple to operate and utilise for our website. Acunetix is a program that analyses web applications for exploitable defects like SQL injection and cross-site scripting. It is used to evaluate the security of online applications. Acunetix typically scans any website or online application that may be accessed using a web browser and uses the HTTP/HTTPS protocol.

Acunetix offers a powerful and distinctive approach to evaluating pre-built and bespoke online applications, including those that make use of JavaScript, AJAX, and Web 2.0 technologies. A sophisticated crawler on Acunetix can locate practically any file. This is crucial, because something cannot be verified without being found. Finding a bug is crucial for making a perfect application.

Configuring and working of Acunetix

Begin by downloading Acunetix from the internet. The link is <https://acunetix-web-vulnerability-scanner.software.informer.com/download/#downloading>. It has a trial version, but is a subscription based application.



Figure 1: Login page of Acunetix

Next, install the application. You need to create a profile with user name and password. We can see the login page in Figure 1.

The application gets opened in '13443' port by default. In case a process is running on that port, you can change it while starting the application.

After you log in, you will be taken to the dashboard, where you can see your overall test results. Figure 2 shows an example of a dashboard.

For running a new scan, go to *Targets* and then click on 'Add Target'. A pop-up appears as shown in Figure 3.

Enter the hosted address of the application and description. Then click on 'Add Target'.

After adding *Target*, you will be taken to a page where you can select scan speed, and business criticality. Next, you can give the instructions to log in. Figure 4 gives an image of the page.

You can either give user name and password or give instructions on the flow of the login. Figure 5 shows the login instruction settings page.

Some of the default settings will be taken based on the website and we can change these if we want to. We can select the type of browser to check the application in, and if we want to exclude any paths we can mention that in the settings. Figure 6 shows the crawl settings.

There are some HTTP and advanced settings that we can control according to our requirements. Figure 7 shows the HTTP settings and Figure 8 shows the advanced settings.

After we have selected the required setting, click on 'Scan'. Then the pop-up shown in Figure 9 comes up.

We can select the type of scan based on our requirements. We can schedule scans like instant scan, scheduled scan or a recurring scan.